[un]prompted

The AI Practitioner Conference

Microsoft Security FORGE Lab: The Next Journey

Taesoo Kim

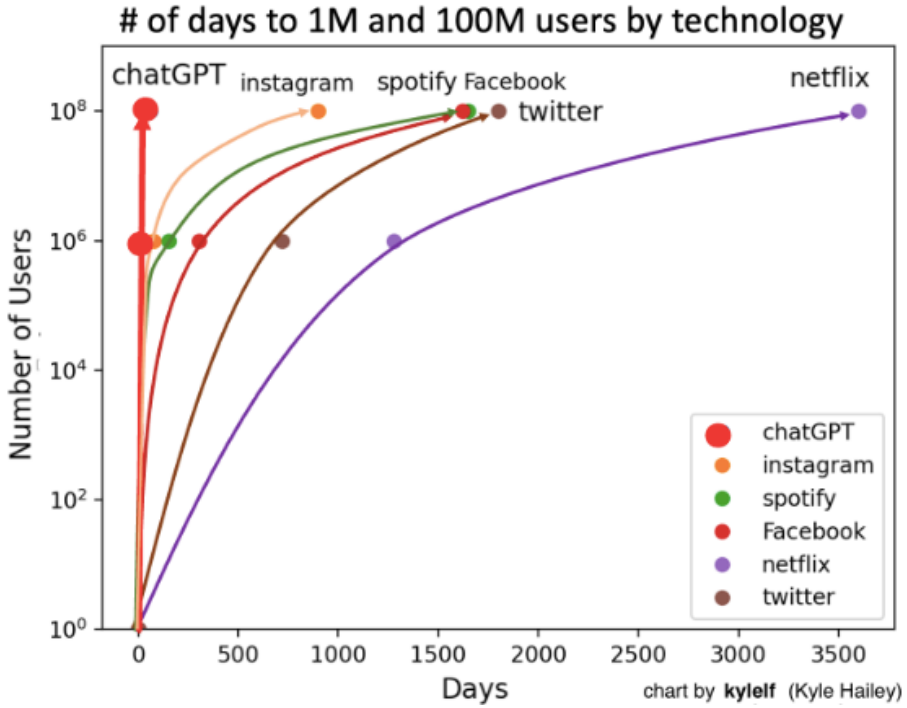
VP, Security Research at Microsoft

ChatGPT moment

Communities started realizing the potentials of LLMs


Attention Is All You Need

Ashish Vaswani* Google Brain avaswani@google.com
Noam Shazeer* Google Brain noam@google.com
Niki Parmar* Google Research nikip@google.com
Jakob Uszkoreit* Google Research usz@google.com
Llion Jones* Google Research llion@google.com
Aidan N. Gomez* † University of Toronto aidan@cs.toronto.edu
Łukasz Kaiser* Google Brain lukaszkaiser@google.com
Illia Polosukhin* ‡ illia.polosukhin@gmail.com

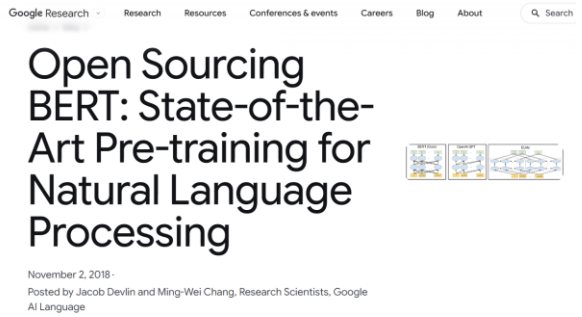


GPT-1

GPT-3

ChatGPT

08/2017 11/2018 06/2020 11/2022


Google Research · Research · Resources · Conferences & events · Careers · Blog · About · Search

Open Sourcing BERT: State-of-the-Art Pre-training for Natural Language Processing

November 2, 2018 ·
Posted by Jacob Devlin and Ming-Wei Chang, Research Scientists, Google AI Language

Ref. AI Timeline (2020–2026) — Every Major Milestone | Machine Brief

ChatGPT moment in security

DARPA AI Cyber Challenge (AIxCC) announcement



What's the frontier cyber capability of LLM?

08/2017 11/2018 06/2020 11/2022 08/2023

DEFCON

KUDU DYNAMICS A Leidos Company

BLUESKY INNOVATORS

UNDAUNTED

theDifference

NTIA

STIF

SPA

OpenSSF

ANTHROP\C

Dazzle Cat Duo

RHAPSODE CONSULTING

Google

ses

Designated Defense

CROMULENCE

Microsoft

NIST

LINCOLN LABORATORY MASSACHUSETTS INSTITUTE OF TECHNOLOGY

Mayhem

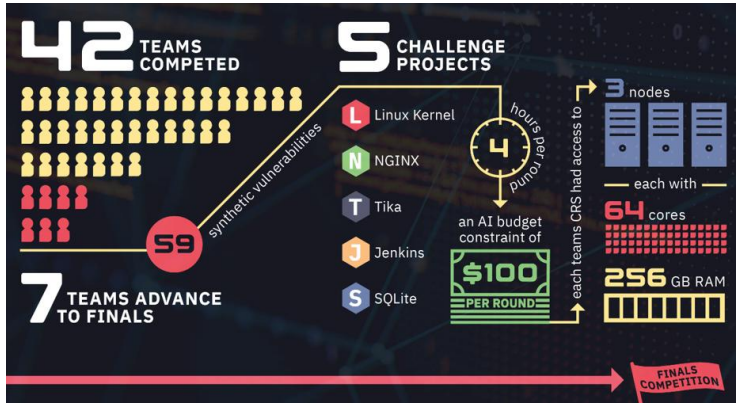
OpenAI

CMS.gov

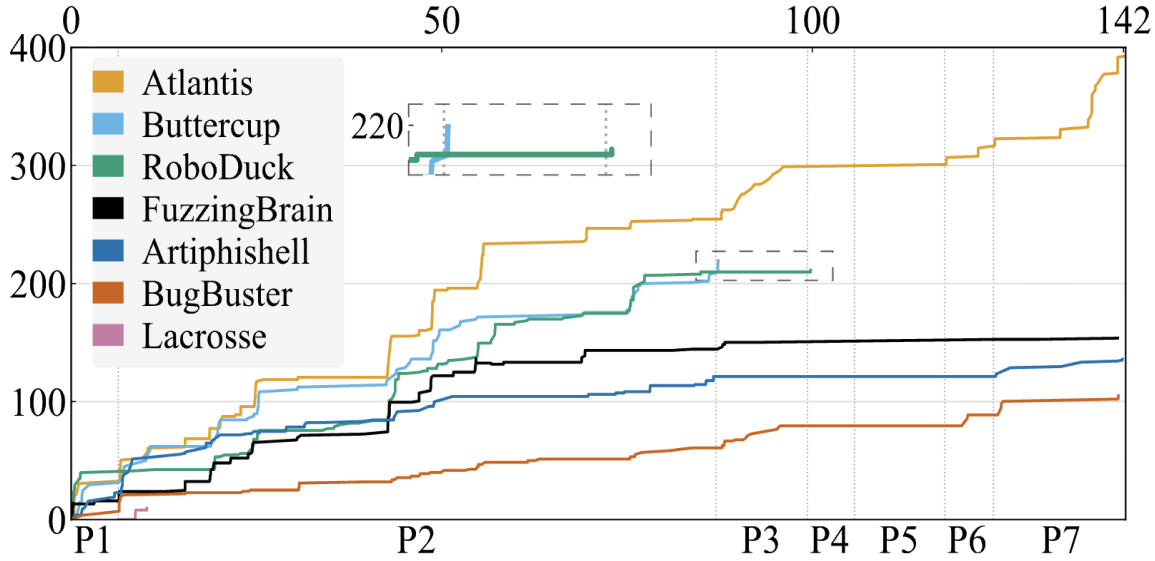
Ref. aicyberchallenge.com

DARPA AIxCC pushes AI-driven vuln. research

DARPA AIxCC is a $30m wake-up call to the security communities!



Ref. https://arxiv.org/abs/2602.07666



08/2023 — 08/2025

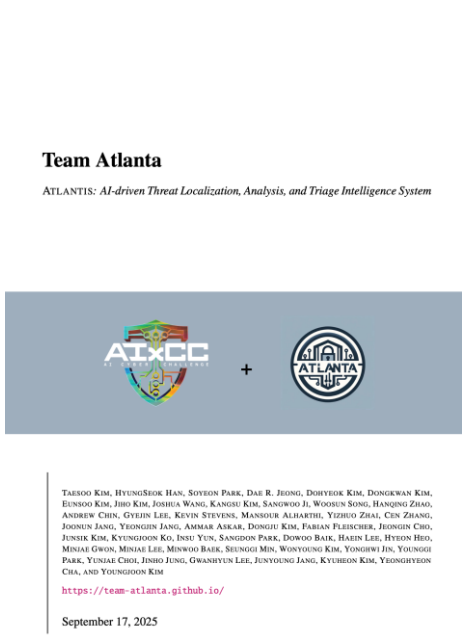




Team	Team Total Score	% Correct Submission (r)	Vulnerability Discovery Score (VDS)	Program Repaid Score (PRS)	SARIF Assessment Score (SAS)	Bundle Score (BDL)
Team Atlanta (9caa56)	**392.76**	91.27%	79.71	171.10	5.99	136.38
Trail of Bits (309958)	**219.35**	89.33%	52.49	101.21	1.00	65.29
Theori (3fad2e)	**210.68**	44.44%	58.12	110.34	4.97	53.57
All You Need IS A Fuzzing Brain (1b9bb5)	**153.70**	53.77%	54.81	77.60	6.52	28.28
Shellphish (463287)	**135.89**	94.83%	47.94	54.31	8.47	25.29
42-b3yond-6ug (ee79d5)	**105.03**	89.23%	70.37	14.22	9.80	10.97
Lacrosse (e87a4d)	**9.59**	42.86%	1.68	5.43	0.00	3.62

https://team-atlanta.github.io/

TL;DR. Open Source + Publication!



Team Atlanta

ATLANTIS: *AI-driven Threat Localization, Analysis, and Triage Intelligence System*

Taesoo Kim, HyungSeok Han, Soyeon Park, Dae R. Jeong, Dohyeok Kim, Dongkwan Kim, Eunsoo Kim, Jiho Kim, Joshua Wang, Kangsu Kim, Sangwoo Ji, Woosun Song, Hanqing Zhao, Andrew Chin, Gyejin Lee, Kevin Stevens, Mansour Alharthi, Yizhuo Zhai, Cen Zhang, Joonun Jang, Yeongjin Jang, Ammar Askar, Dongju Kim, Fabian Fleischer, Jeongin Cho, Junsik Kim, Kyungjoon Ko, Insu Yun, Sangdon Park, Dowoo Baik, Haein Lee, Hyeon Heo, Minjae Gwon, Minjae Lee, Minwoo Baek, Seungi Min, Wonyoung Kim, Yonghwi Jin, Younggi Park, Yunjae Choi, Jinho Jung, Gwanhyun Lee, Junyoung Jang, Kyuheon Kim, Yeonghyeon Cha, and Youngjoon Kim

https://team-atlanta.github.io/

September 17, 2025

Version 1.0

ATLANTIS
150+pg TR





SoK: DARPA's AI Cyber Challenge (AIxCC): Competition Design, Architectures, and Lessons Learned

Cen Zhang[†] Younggi Park[‡] Fabian Fleischer[†] Yu-Fu Fu[†] Jiho Kim[†] Dongkwan Kim[†] Youngjoon Kim[†]
Qingxiao Xu[‡] Andrew Chin[†] Ze Sheng[‡] Hanqing Zhao[†] Brian J. Lee[†] Joshua Wang[†]
Michael Pelican[¶] David J. Musliner[¶] Jeff Huang[‡] Jon Silliman[†] Mikel Mcdaniel[†]
Jefferson Casavant[†] Isaac Goldthwaite[†] Nicholas Vidovich[†] Matthew Lehman[†] Taesoo Kim[†*]

[†] *Georgia Institute of Ta*
[¶] *Smart Information*

Abstract—DARPA's AI Cyber Challenge is the largest competition to date for build Cyber Reasoning Systems (CRSs) that leve in AI—particularly large language mod cover and remediate vulnerabilities in re software. This paper presents the first s AIxCC. Drawing on design documents, so traces, and discussions with organizers and examine the competition's structure and characterize the architectural approaches analyze competition results beyond the fi analysis reveals the factors that truly dro identifies genuine technical advances ach exposes limitations that remain open for conclude with lessons for organizing futu broader insights toward deploying autonom

1. Introduction

Open-source software (OSS) under tructure, yet scaling vulnerability discov remains challenging. DARPA's AI Cyber 2023–2025) addresses this by challeng fully autonomous Cyber Reasoning S leverage large language models (LLM patch vulnerabilities in real-world C ans final competition in August 2025 rep scale evaluation of autonomous vulne date: around 143 hours of fully autonom from seven finalist teams analyzed 53 derived from critical infrastructure softv with $85K in cloud compute and 500K

Despite the competition's complet study has examined AIxCC's design rat approaches employed by participating t that emerged from this large-scale co analysis would benefit multiple comm organizers designing future challenges,

arXiv:2602.07666v2 [cs.CR] 18 Feb 2026

CtxFuzz: Context-Aware Directed Fuzzing via Runtime Fuzzer-Agent Cooperation

Jiho Kim, Georgia Institute of Technology, Atlanta, USA, jkim4050@gatech.edu
Dongkwan Kim, Georgia Institute of Technology
HyungSeok Han, Microsoft
Youngjoon Kim, Georgia Institute of Technology, Atlanta, USA, youngjoon.kim@gatech.edu
Joshua Wang, Georgia Institute of Technology, Atlanta, USA, jwang3433@gatech.edu

Abstract

Automated tools produce vulnerability n scale, but turning a report into a confirme remains challenging. Directed grey-box fu validation but lack the ability to consum reports carry, reducing each target to a b LLM-based approaches can consume th unable to identify the true triggering mech working proof-of-vulnerability.

We present CtxFuzz, a context-aware ables an LLM agent and a coverage-guide change and refine bug-triggering context t The fuzzer contributes execution context, tried and how the program behaved, gross ing in concrete evidence. The agent contr including hypotheses about the triggering of failed attempts, and targeted mutations ing the fuzzer toward relevant regions of t tempts are not discarded but decomposed translate each identified blocker into a fu This iterative exchange enables CtxFuzz that neither directed fuzzers nor LLM age

On 62 vulnerabilities across 16 open-s AIxCC Final competition (39 C, 23 Java), 62 targets, including 29 that no state-of reaches, and exposes two zero-day vulne world vulnerability report validation pipe

CCS Concepts

• Security and privacy → Software sec

This work is licensed under a Creative Commons Attri ASE '26, Munich, Germany
© 2026 Copyright held by the owner/author(s).
ACM ISBN 979-8-4007-2092-5/2026/10
https://doi.org/10.1145/3810783.3810843

OSS-CRS: Liberating AIxCC Cyber Reasoning Systems for Real-World Open-Source Security

Andrew Chin[†] Dongkwan Kim[†] Yu-Fu Fu[†] Fabian Fleischer[†] Youngjoon Kim[†]
HyungSeok Han[‡] Cen Zhang[†] Brian Junekyu Lee[†] Hanqing Zhao[†] Taesoo Kim[†‡]
[†] *Georgia Institute of Technology*, [‡] *Microsoft*

Abstract—DARPA's AI Cyber Challenge (AIxCC) showed that cyber reasoning systems (CRSs) can go beyond vulnerability discovery to autonomously confirm and patch bugs; seven teams built such systems and open-sourced them after the competition. Yet all seven open-sourced CRSs remain largely unusable outside their original teams, each bound to the competition cloud infrastructure that no longer exists. We present OSS-CRS, an open, locally deployable framework for running and combining CRS techniques against real-world open-source projects, with budget-aware resource management. We ported the first-place system (ATLANTIS) and discovered 10 previously unknown bugs (three of high severity) across 8 OSS-Fuzz projects. OSS-CRS is publicly available.

1. Introduction

AI-generated vulnerability reports [4, 18, 36, 47] are increasing the burden on open-source maintainers. The curl project shut down its bug bounty program after AI-written submissions overwhelmed reviewers with unconfirmed findings [45, 46]; FFmpeg maintainers criticized Google for reporting valid bugs without providing patches, calling the reports "CVE slop" [42]. In both cases, AI automation stops at discovery, leaving maintainers to validate findings and write fixes.

DARPA's AI Cyber Challenge (AIxCC, 2023–2025) [15] demonstrated that the gap between vulnerability discovery and validated remediation can be closed. Seven finalist teams built autonomous cyber reasoning systems (CRSs) that go beyond discovery: each CRS dynamically confirms a vulnerability with a proof of vulnerability (PoV) and synthesizes a patch validated against that PoV [14]. After the competition, all seven teams open-sourced their systems, in principle making it possible to deploy this capability against any open-source project.

Yet over half a year later, these CRSs remain largely unusable outside their original teams: each system is bound to team-specific infrastructure and interfaces. This adoption gap blocks the communities that should benefit from these systems: researchers cannot run comparable cross-CRS experiments under consistent settings; CRS developers lack a stable integration contract; and security practitioners cannot adopt deployable, budget-aware workflows that produce actionable findings.

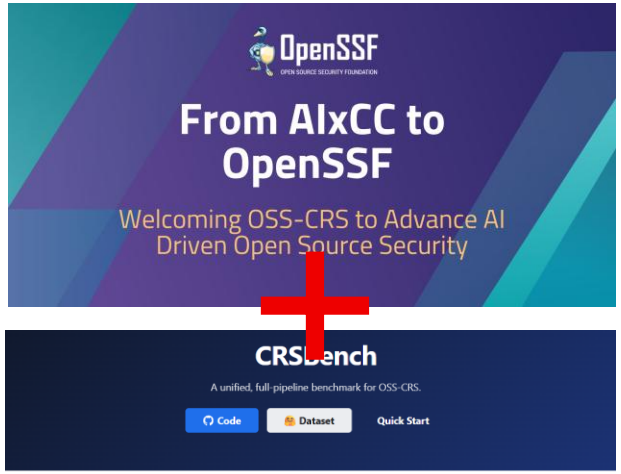
To understand what prevents adoption, we analyzed the open-sourced codebases of all seven AIxCC finalists and identify three deployment barriers: ❶ *Infrastructure duplication*, each team independently rebuilt the same platform services; ❷ *Cloud lock-in*, every system targets the competition's Azure and Kubernetes environment, which was decommissioned after the finals; and ❸ *Monolithic design*, analysis techniques are embedded in monolithic systems, preventing researchers from comparing or combining them across teams. Even ATLANTIS, the first-place system [24], requires over 20 Azure virtual machines and cannot target new projects without its original cloud environment.

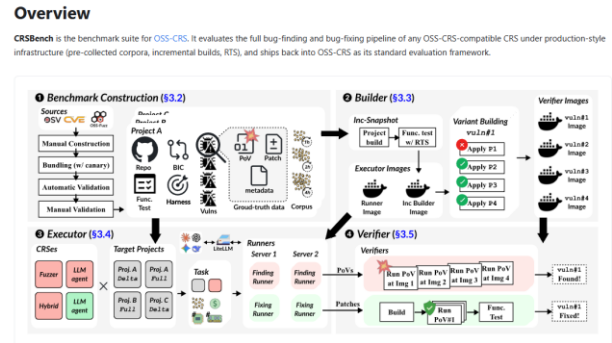
To address these barriers, we present OSS-CRS [37], an open framework for developing, running, and composing CRSs on real-world open-source projects. OSS-CRS provides a shared infrastructure layer including LLM budget management and cross-CRS artifact exchange, so that CRS developers can focus on analysis logic rather than platform engineering. It adopts the OSS-Fuzz [3] project format as its target interface, enabling any integrated CRS to target over 1,000 OSS-Fuzz projects without per-project customization. To validate the framework, we ported ATLANTIS and ran it against 8 OSS-Fuzz projects, discovering 10 previously unknown bugs, including three of high severity. OSS-CRS and all integrated CRSs are publicly available.

This paper makes the following contributions:

- An *empirical analysis* of all seven AIxCC finalist CRS codebases, identifying three deployment barriers that prevent practical reuse: infrastructure duplication, cloud lock-in, and monolithic design (§2).
- OSS-CRS, an open-source framework that addresses these barriers through a unified execution model and standard interface, budget-aware resource management across CPU, memory, and LLM usage, and support for combining CRS techniques across systems (§3).
- *Real-world validation*: porting ATLANTIS to OSS-CRS and discovering 10 previously unknown bugs (three of high severity) across 8 OSS-Fuzz projects, showing that competition-grade CRS techniques can be deployed without cloud infrastructure (§4, §5).

SoK: AIxCC CRS (USENIX Security'26)
CtxFuzz (ASE'26)
PatchIsland (ACSAC'26)
OSS-CRS (WOOT'26)



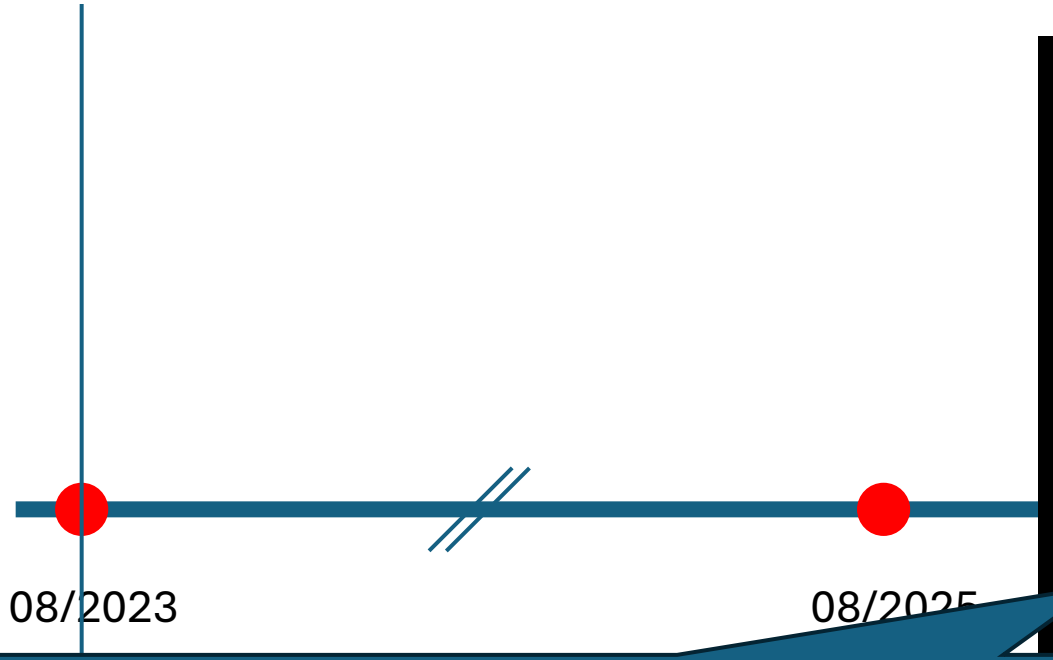


OSS-CRS & CRS-Bench
OpenSSF

https://oss-crs.openssf.org/crsbench

A wake-up call to security communities

DARPA AIxCC proves the feasibility of pushing the frontier cyber capability of LLMs





AI can conduct professional-level cyber tasks
(e.g., $150 / task)

AIxCC crews sparked new industries

Racing on improving cyber capabilities by frontier AI companies



08/2023

Google Big Sleep

08/2025

CodeMender (DeepMind)

10/2025

Aardvark (OpenAI)

02/2026

Claude Code Security (Anthropic)

03/2026

Codex Security Review (OpenAI)

06/2026

MDASH (Microsoft)

OSS communities followed

Dev communities looked skeptical about AI-driven vuln rese

Daniel Stenberg
curl CEO. Code Emitting Organism
3mo · Edited

That's it. I've had it. I'm putting my foot down on this craziness.

1. Every reporter submitting security reports on #Hackerone for #curl now needs to answer this question:

"Did you use an AI to find the problem or generate this submission?"

(and if they do select it, they can expect a stream of proof of actual intelligence follow-up questions)

2. We now ban every reporter INSTANTLY who submits reports we deem AI slop. A threshold has been reached. We are effectively being DDoSed. If we could, we would charge them for this waste of our time.

We still have not seen a single valid security report done with AI help.

6,698 · 265 Comments

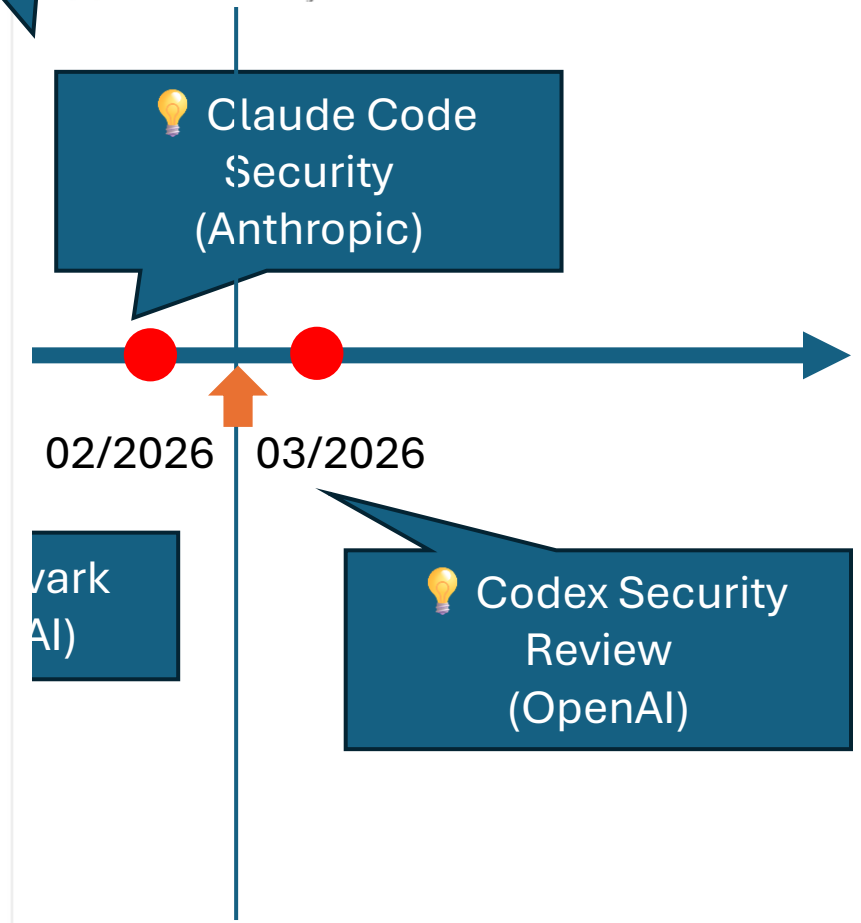
Daniel Stenberg • 2nd
curl CEO. Code Emitting Organism
3w

+ Follow

When we announce over 20 new #curl CVEs on October 14, you will learn that every single one of them were found by clever humans using harnesses powered by AI models. Every. Single. One.

The holy trinity of modern vulnerability research.

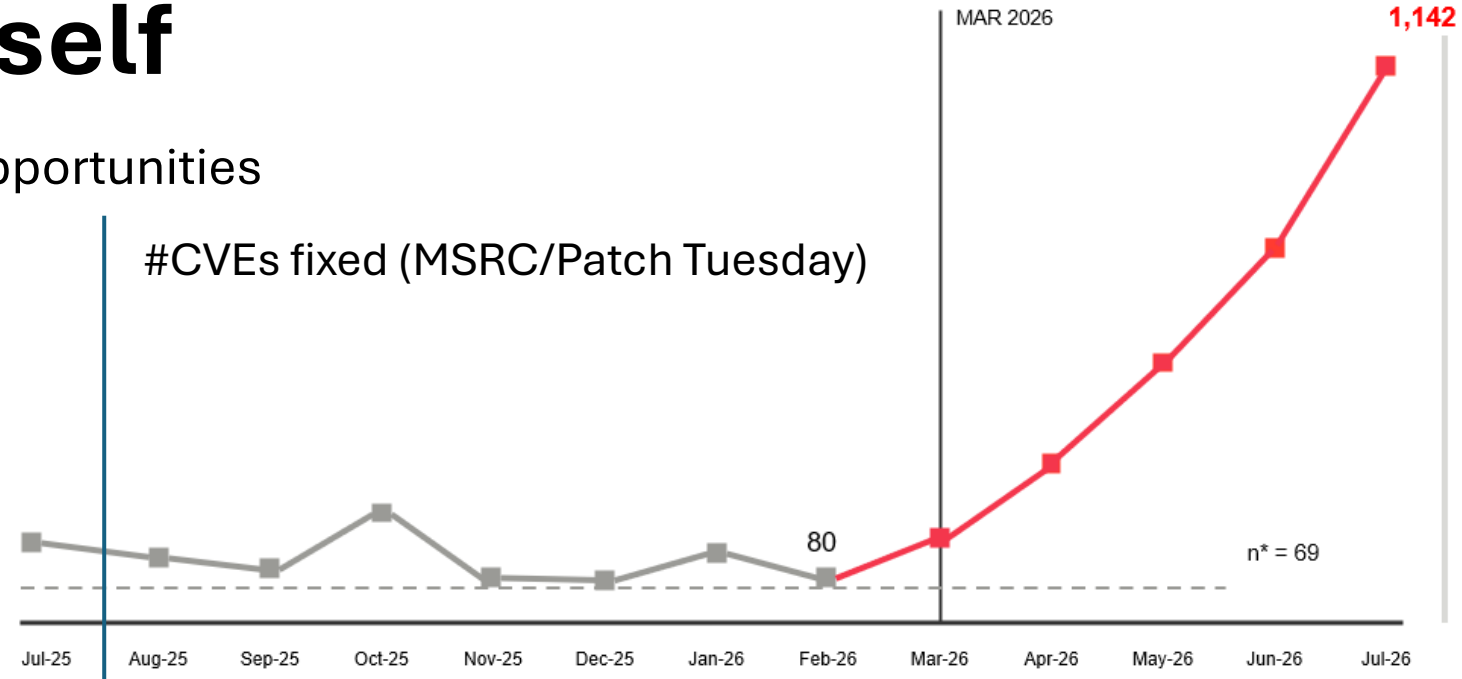
Vlatko Kosturjak and 574 others — 32 comments • 33 reposts



#CVEs speaks itself

Skepticism to excitement and opportunities

#CVEs fixed (MSRC/Patch Tuesday)



08/2023 — 08/2025 — 10/2025 — 02/2026 — 03/2026

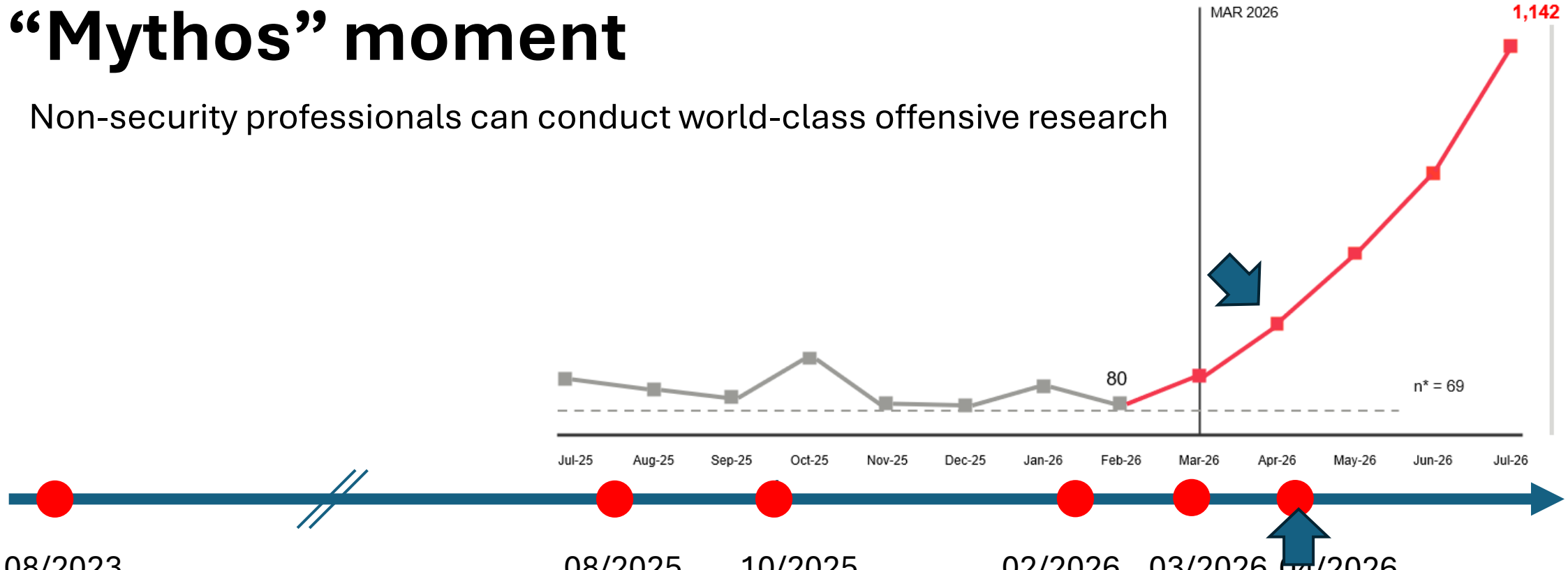


NOW!

< 1 year

“Mythos” moment

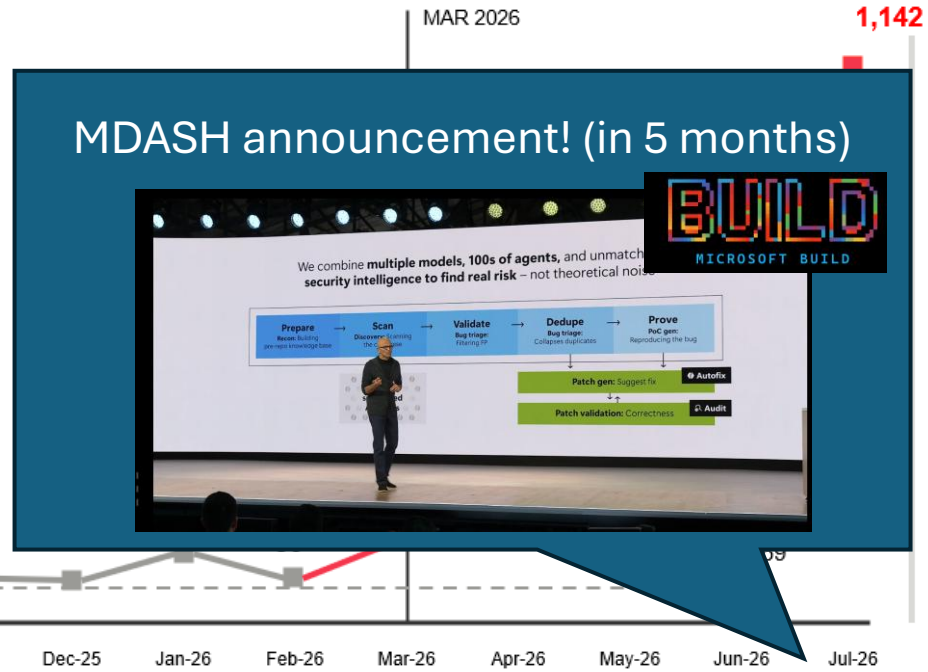
Non-security professionals can conduct world-class offensive research





Team Atlanta → Microsoft

Five members of Team Atlanta joins Microsoft Security



08/2023 08/2025 10/2025 02/2026 03/2026 04/2026 06 026

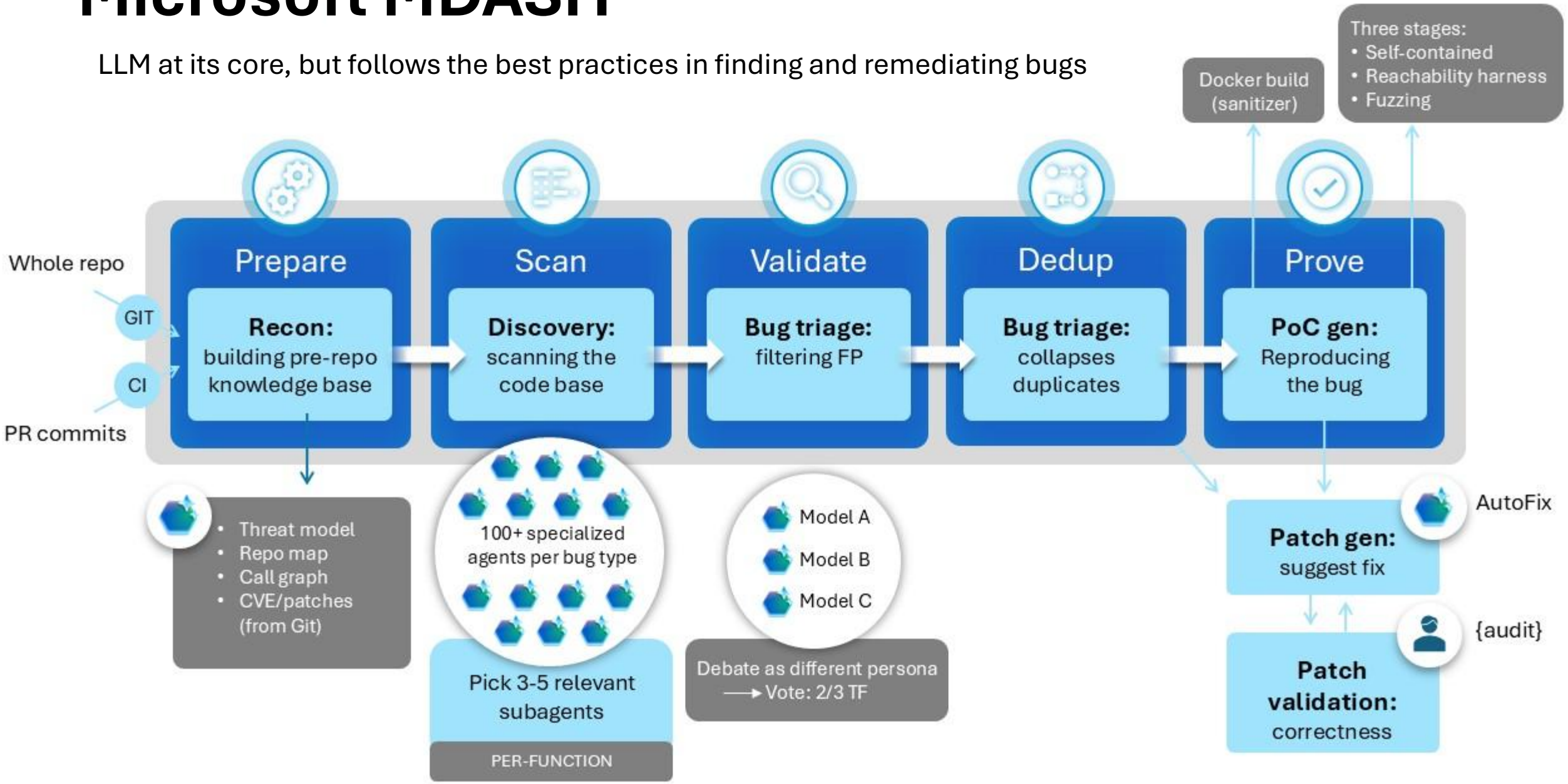


ATLANTA → Microsoft

(+ DeepMind, OpenAI, Armadin, XBOW, QED)

Microsoft MDASH

LLM at its core, but follows the best practices in finding and remediating bugs



Idea 1. Search problem → decision problem

1. *cost-effective*
2. *good at spotting **one** likely bug*
   → keep continuing?
3. *AGI. nicely w/ a powerful model*

$ copilot –p “find memory-safety bugs in the repo”

$ copilot –p “find memory-safety bugs in the code **@file.c**”

$ copilot –p “find memory-safety bugs in the **function foo()** @file.c”

$ copilot –p “does foo()@file.c contain a **memory-unsafe** bug?”

$ copilot –p “does foo()@file.c contain a **UAF** bug?”

$ copilot –p “does **foo():L20@file.c** have an integer overflow bug?”

We experienced that
the more concrete questions render
higher success rate (avoiding hallucination)!
yet hard to scale 🥹

Idea 2. Function as unit for orchestration

Function as an orchestration unit

1. Embarrassingly parallel in per-file and per-agent. Scaling to1000+ agents!

CORE:

For ***each function,***

```
$ copilot –p “find UAF bugs in foo()@file.c?” &
$ copilot –p “find int ovfls in foo@file.c?” &
$ copilot –p “find windows symlink bugs in foo@file.c” &

....
```

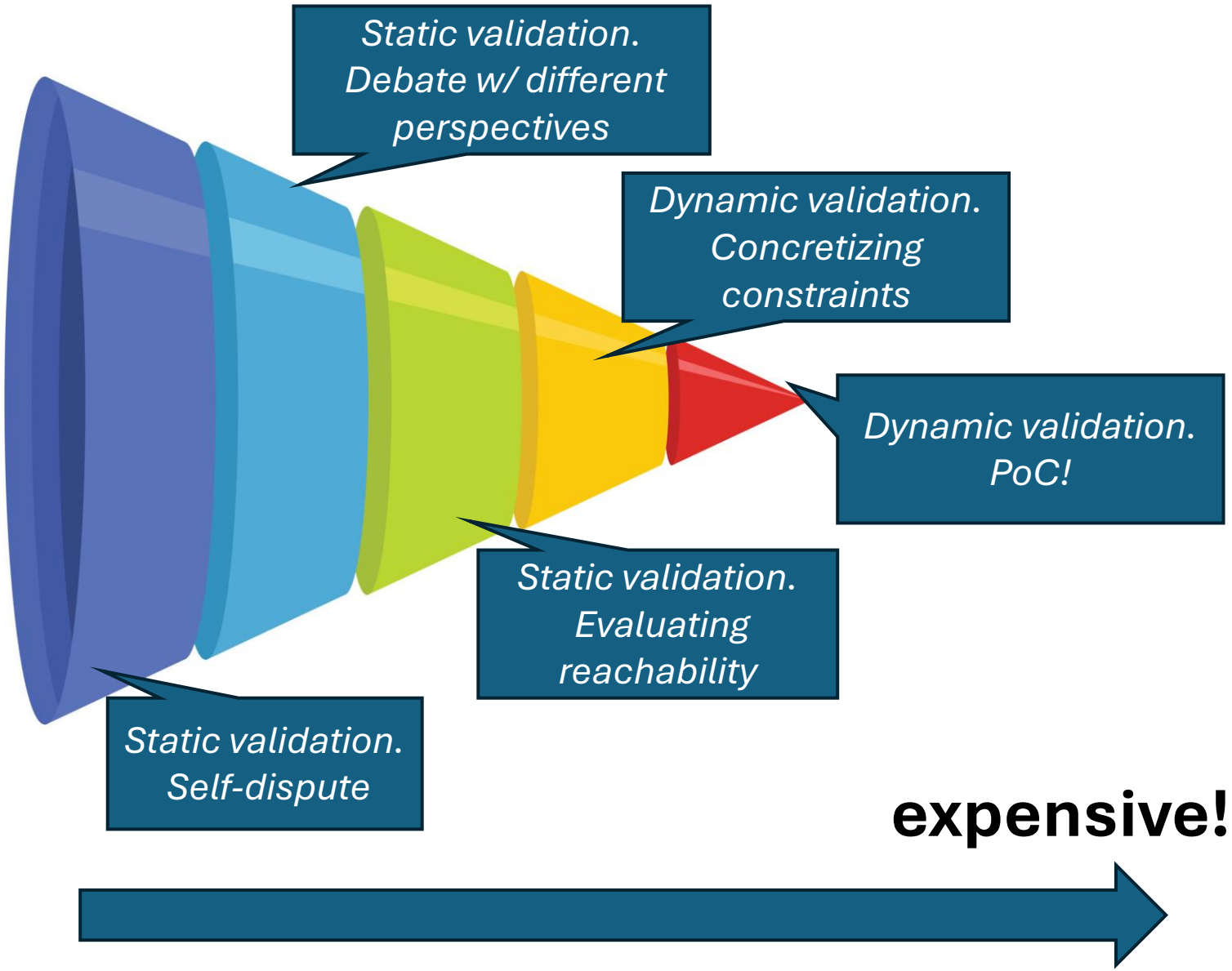
2. Frist spotting all “suspicious” places quickly

Idea 3. Scaling via funneling

CORE:

For ***each function,***





Idea 4. Enrichment: annotated source code

LAYERS Vuln 15 Bounds 48 Flow 52 Control 3 Safety 9 Meta 6

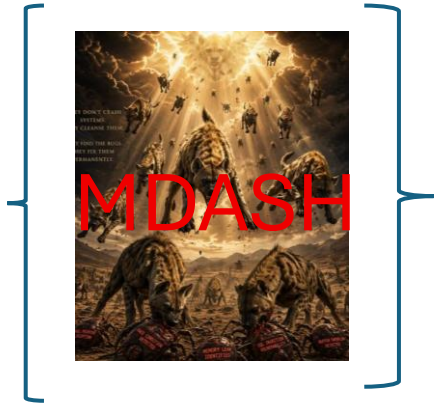
133 annotations across 114 lines

```
HISTORY  fts5_index.c
1  static void fts5DoSecureDelete(
TAINT  p->rc accumulates errors; p->pConfig->eDetail is trusted config
2    Fts5Index *p,
TAINT  pSeg->pLeaf->p (aPg), pSeg->pLeaf->nn (nPg), pSeg->pLeaf->szLeaf (iPgIdx) all derive from blob data read from %_data — fully attacker-controlled
3    Fts5SegIter *pSeg
4  ){
DATA FLOW  FTS5_DETAIL_NONE path omits position-list size varint; affects how iNextOff is computed
5    const int bDetailNone = (p->pConfig->eDetail==FTS5_DETAIL_NONE);
TAINT  segment id from shadow table structure record; used in FTS5_SEGMENT_ROWID() for row lookups
6    int iSegid = pSeg->pSeg->iSegid;
TAINT  raw page bytes from attacker-controlled blob
BOUNDS  buffer is pSeg->pLeaf->nn bytes + FTS5_DATA_PADDING=20 zero-padded bytes
7    u8 *aPg = pSeg->pLeaf->p;
TAINT  total page size in bytes (attacker-controlled blob size); int, ≤ INT_MAX
8    in        pSeg->pLeaf->nn;
TAINT                                   ed, range 0–65535
```

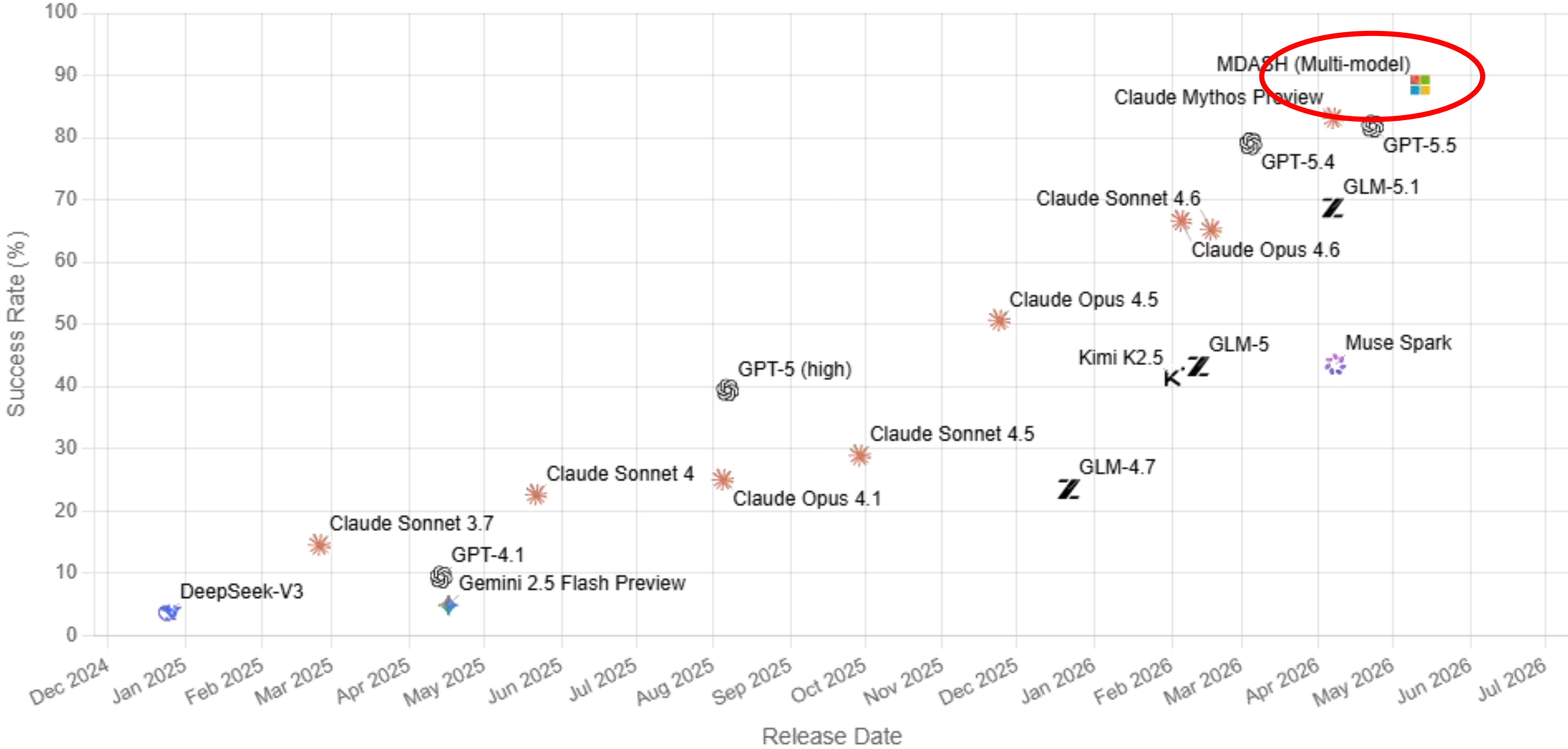
2. LLM is really good at appending this annotations (e.g., TAINT, BOUNDARY, etc)

CORE:

For ***each function,***



*1. **Inlined** perspective of each constraints help removing hallucination + spotting more likely suspicious places*


MDASH (Multi-model)
Claude Mythos Preview
GPT-5.5
GPT-5.4
GLM-5.1
Claude Sonnet 4.6
Claude Opus 4.6
Claude Opus 4.5
GLM-5
Kimi K2.5
Muse Spark
GPT-5 (high)
Claude Sonnet 4.5
GLM-4.7
Claude Sonnet 4
Claude Opus 4.1
Claude Sonnet 3.7
GPT-4.1
Gemini 2.5 Flash Preview
DeepSeek-V3
Success Rate (%)
Release Date
100
90
80
70
60
50
40
30
20
10
0
Dec 2024
Jan 2025
Feb 2025
Mar 2025
Apr 2025
May 2025
Jun 2025
Jul 2025
Aug 2025
Sep 2025
Oct 2025
Nov 2025
Dec 2025
Jan 2026
Feb 2026
Mar 2026
Apr 2026
May 2026
Jun 2026
Jul 2026

AI

July 9, 2026

Evolving Win vulnerability managemen the speed of AI-powered discovery

By Pavan Davuluri, Executive Vice President, Windows + Devices

Finding vulnerabilities earlier and at greater scale

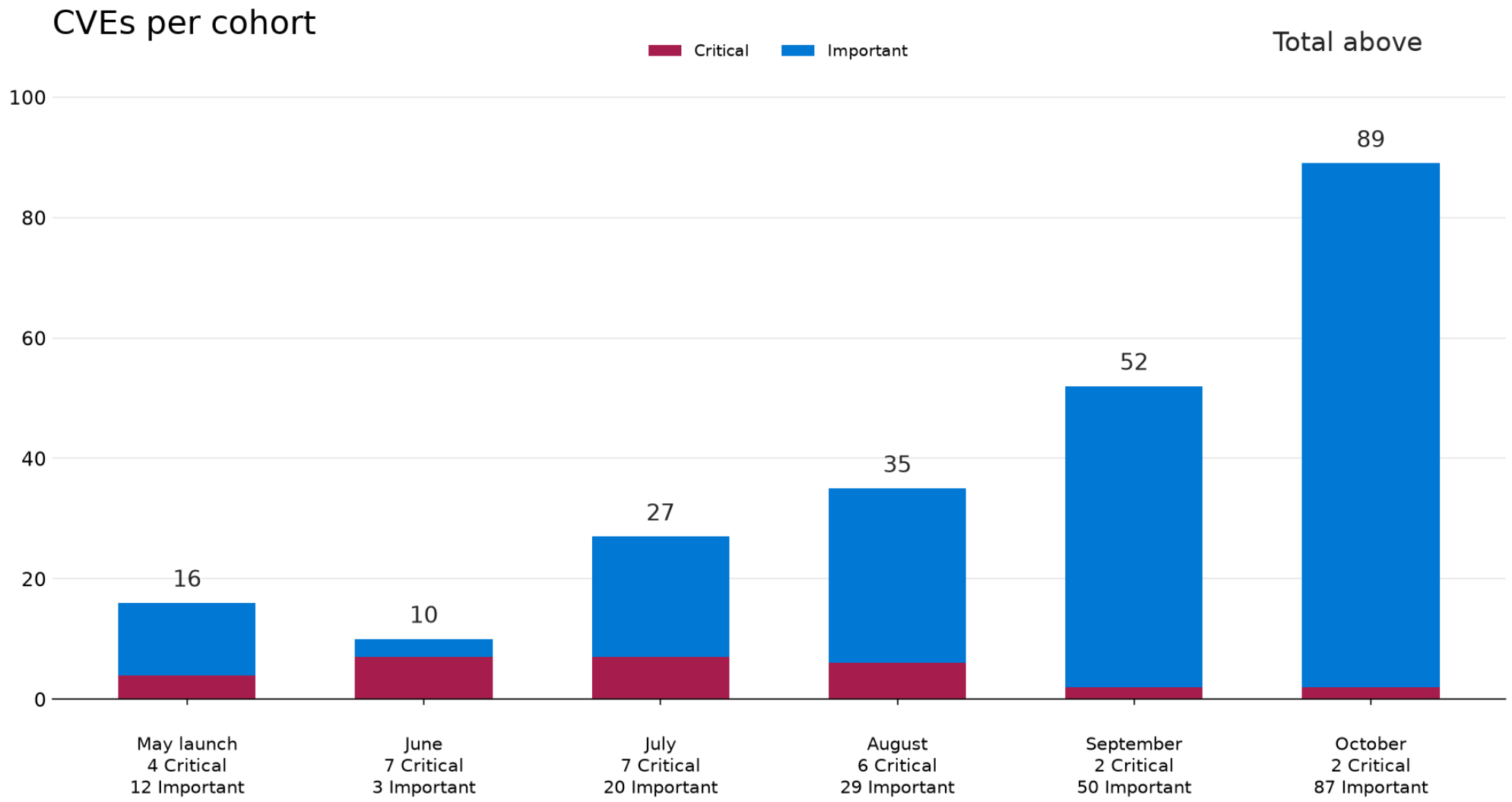
By applying AI across security analysis, we can identify patterns faster, prioritize risk and scale vulnerability discovery across the Windows codebase. This helps reduce the time between discovery and customer protection. It includes using Microsoft Security's multi-model agentic scanning harness (MDASH), which utilizes multiple models including leading third-party AI vulnerability discovery models.

To run MDASH at Windows scale, Windows set up dedicated cloud infrastructure for scanning and proving. A scanner pipeline scans critical binaries and validates candidates using multi-model debate across multiple model families. Confirmed candidates then flow to a separate, Windows-specific prove pipeline that helps eliminate remaining false positives, so only the highest-confidence findings reach the engineering team. This automation helps handle a larger volume of potential vulnerabilities and shortens the review window for new ones, shrinking the attack window for zero-day exploits.



CVEs fixed by MDASH on Windows / HyperV

229 CVEs critical / important bugs fixed including 38 RCEs (7.7 CVSS on average)



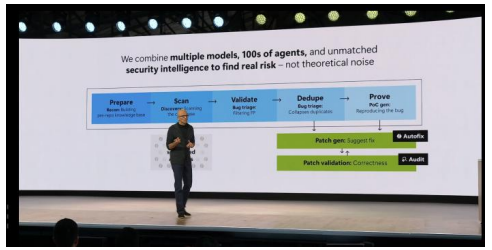
Singularity on hybrid approach

The key to scale the bug remediation is to reduce the noise (i.e., FP rates)

ATLANTIS

MDASH





Dynamic

Static

?

Fuzzing

LLM

Augmenting LLMs

Tooling + Proving

Better applicability

Low false positives

Singularity on hybrid approach

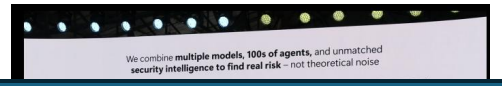
The key to scale the bug remediation is to reduce the noise (i.e., FP rates)

ATLANTIS



Shift 1. From frontier capability to scale

MDASH



Shift 2. From token consumption to reasoning economics

Dynamic

Static

?

Fuzzing

LLM

Shift 3. Validation and remediation as a continuous learning loop

Tooling + Proving

Better applicability
Low false positives

Shift 1.

From frontier capability to scale

Scarcity & Art → **Abundance & Commonplace**

- AI reduces the cost to attack (e.g., powerful script kiddies w/ AI)
- Thus, the scope for security auditing expands broadly
- The key to close this gap is to **reduce the cost (#token) per audit**
  (e.g., small or specialized models, multi models)

Shift 2.

From token consumption to reasoning economics

Security ~= #Tokens used for security reasoning

- Linus's law in AI era: **"given enough tokens, all bugs are shallow"**
- More important questions,
  - What's "enough" (i.e., when to stop)?
  - How cost-effectively consume #token for security reasoning?

Shift 3.

Validation and remediation as a cont. learning loop

Cost

Finding < Triaging << Validation <<< **Deployment**



How to leverage this insight back for better, cost-effective finding?

- Post-discovery is still pricy (i.e., expensive reasoning + manual)
- Ranking #bugs is more important
- How to reuse past lessons, and enable continuous learning loop?

Microsoft FORGE Lab

Frontier Offensive Research & Generative Exploitation (FORGE)



Ironically, ***"exploitation"*** is more important than ever before

(i.e., actionable, in priority)

- **Shift 1** → Focus on finding exploitable bugs
- **Shift 2** → Spend tokens for exploitation reasoning
- **Shift 3** → Use exploit techniques & attack vectors for cont. loop

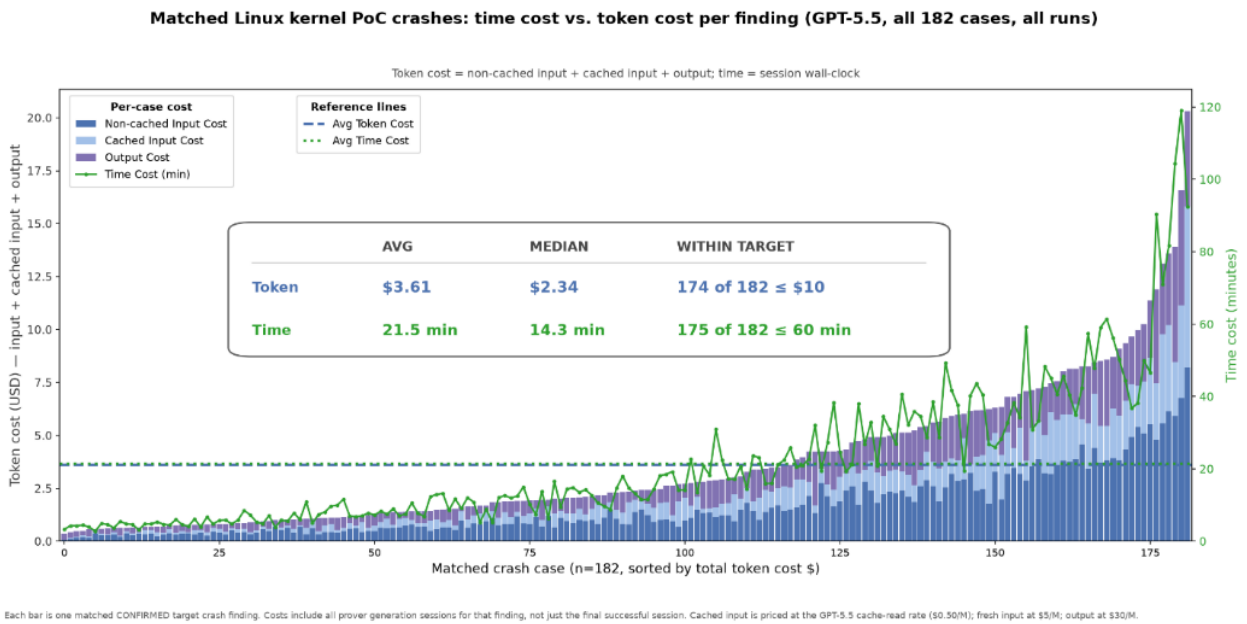
Example: Linux Kernel

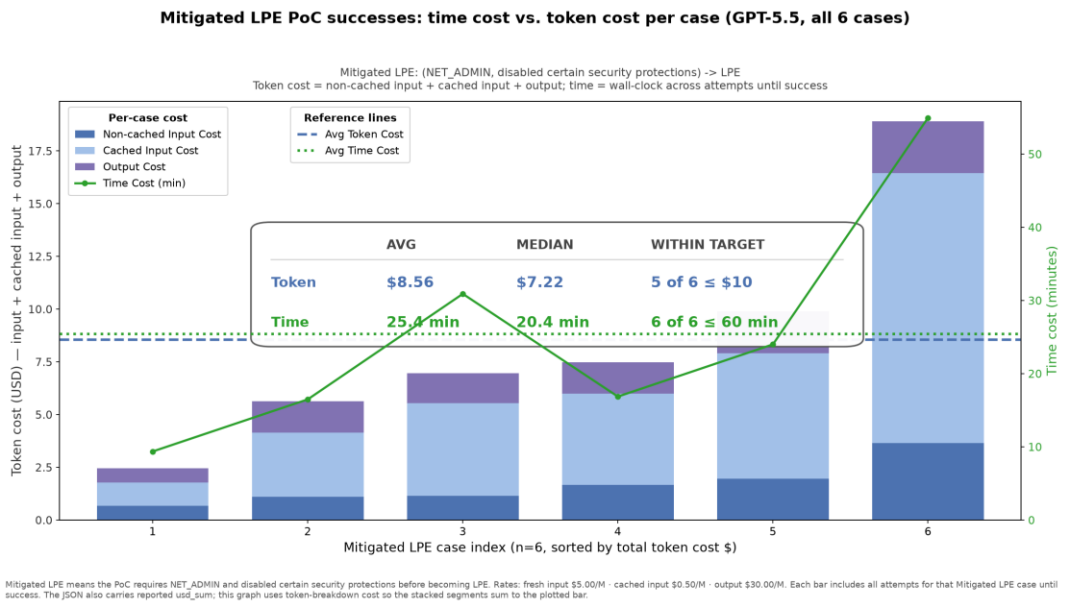
Building automatic exploit generation (AEG) against the Linux kernel

e.g., non-default device driver, non-popular config, corrupted fs image, etc

Given patch/report/crash → LPE/RCE

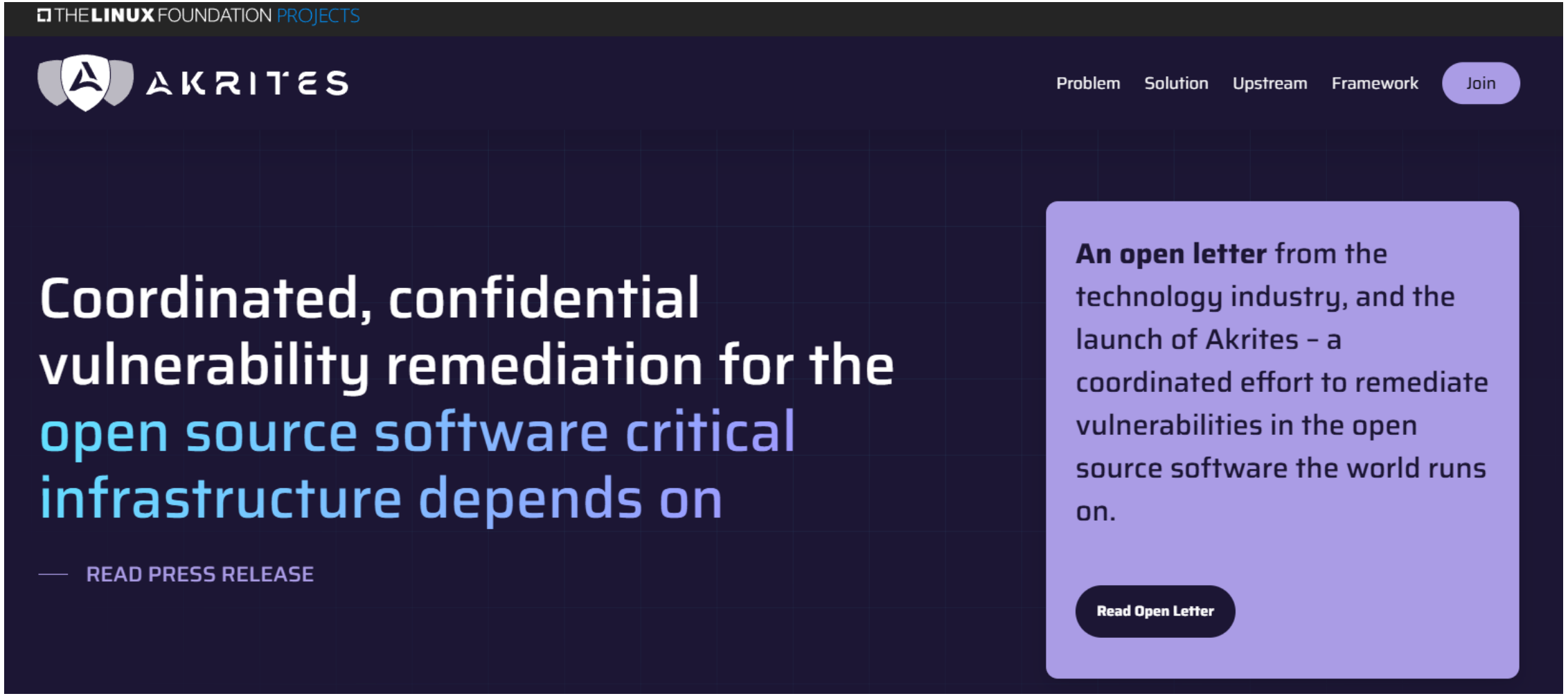
1. MDASH reports → PoC (crash): 5%, $3.6/poc, 600+ reproduced
2. PoC (crash) → Exploit (PoC): 1.8%, 11 LPEs, $10+/exploit





Community-wide efforts to fix/triage bugs

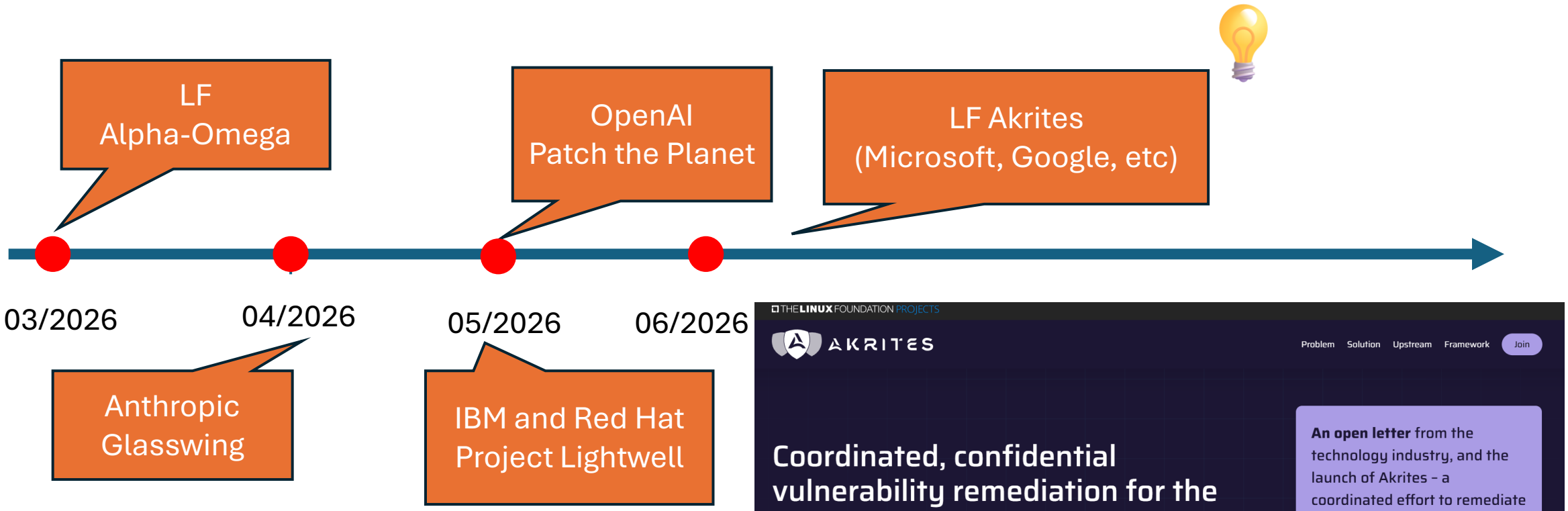
Microsoft works together with the communities under LF Akrites

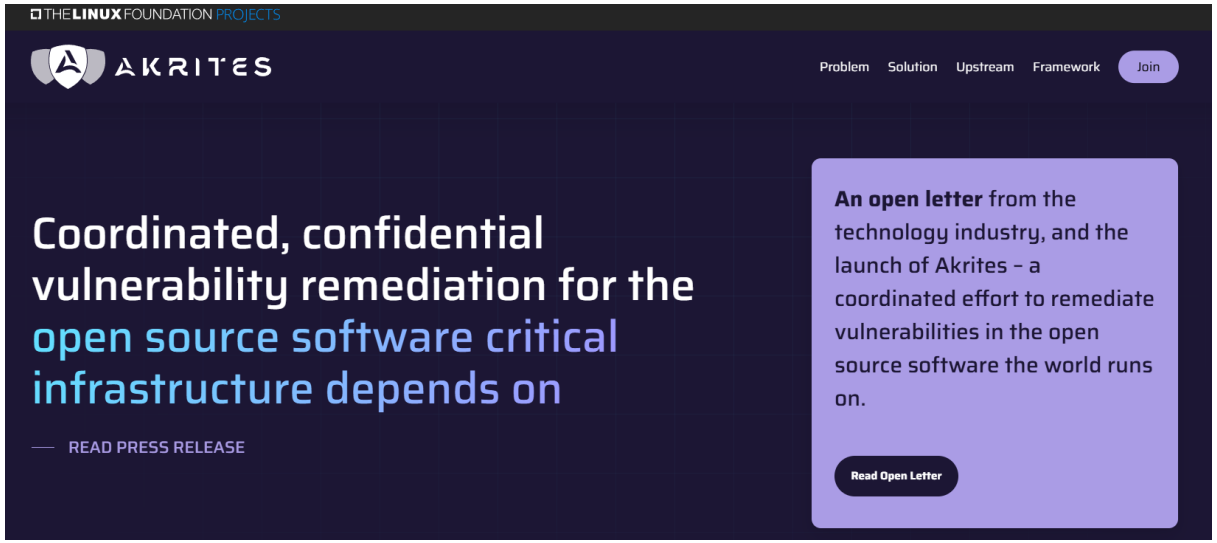


https://github.com/microsoft/forge-lab/blob/main/cve/cve.json

Community-wide efforts to fix/triage bugs

All frontier AI companies spent resources to remediate bugs from OSS projects





Discover what's coming to Microsoft Ignite, Nov 17-20, 2026. Register now.



Taesoo Kim posts

Vice President, Agentic Security, Microsoft

Taesoo Kim is a VP, Security Research at Microsoft (Agentic Security). He is also a Professor in the School of Cybersecurity and Privacy (SCP) and the School of Computer Science (SCS) at Georgia Tech (on-leave). Prof. Kim leads Team Atlanta, which won 1st place in the DARPA AI Cyber Challenge (AIxCC), a competition to build autonomous cyber reasoning systems that detect and remediate software vulnerabilities in open-source projects, earning a total award of $6 million prize. He is the recipient of numerous honors, including the NSF CAREER Award (2018), the Internet Defense Prize from Facebook (2015) and several best paper/artifact awards at premier venues such as SOSP'21, USENIX Security'18, and EuroSys'17. Prof. Kim holds Ph.D. (2014) from MIT EECS/CSAIL.

Research • October 7 • 11 min read

3 lessons from frontier AI vulnerability research >

Read how How Microsoft Security's FORGE Lab is scaling vulnerability research from Windows to the Linux kernel.



News • June 17 • 12 min read

Beyond the benchmark: Advancing security at AI speed >

Read how Microsoft Security has advanced its agentic vulnerability detection system, codename MDASH, integrating into real-world workflows across Windows, Azure, and identity systems.



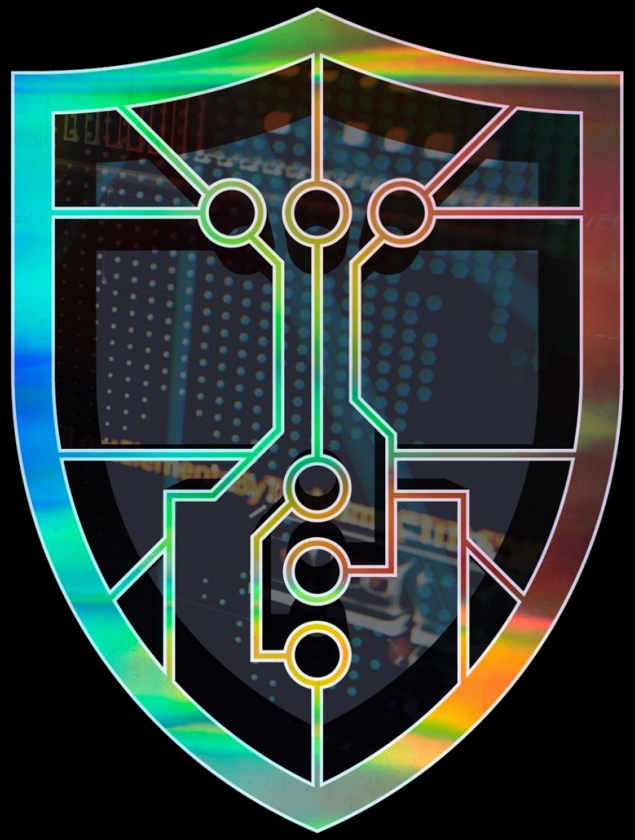
May 12 • 16 min read

Defense at AI speed: Microsoft's new multi-model agentic security system tops leading industry benchmark >

Today Microsoft is announcing a major step forward in AI-powered cyber defense: a new multi-model agentic scanning harness (codenamed MDASH).



DARPA + ARPA-H



AIxCC
AI CYBER CHALLENGE

changed

The world changes today.

Automated patch development is:

Fast
Scalable
Cost-effective
Available / Open-source

NOW

AI + CRS = The Future

Thanks

Taesoo Kim
VP, Security Research at Microsoft

https://www.linkedin.com/in/tsgatesv/
https://taesoo.kim/

[un]prompted

The AI Practitioner Conference